

Huey's Home Lab Build Documentation

Phase 3 — Active Directory Attack & Defense

Session Date: June 2, 2026

1. Phase 3 Overview

This document covers Phase 3 of the cybersecurity home lab build. With Active Directory configured and Kali Linux joined to the hueylab.local domain, this phase focused on real-world Active Directory attack techniques and blue team log analysis. Every attack was performed against our own lab environment and every result was observed from both the attacker and defender perspective.

2. Tools Used

Tool	Purpose	Source
enum4linux	AD enumeration via SMB/RPC	Pre-installed on Kali
CrackMapExec	SMB authentication and share enumeration	Pre-installed on Kali
impacket-GetUserSPNs	Kerberoasting (attempted)	Pre-installed on Kali
Windows Event Viewer	Blue team log analysis	Built into Windows Server
kinit / klist	Kerberos ticket management	Pre-installed on Kali

3. Attack Timeline

Time	Tool	Account Used	Source IP	Result
8:17 PM	enum4linux (anonymous)	None	192.168.99.20	Domain SID, hostname discovered. Users/groups blocked.
8:22 PM	enum4linux (authenticated)	ksayian	192.168.99.20	Full user list, groups, password policy retrieved.
10:48 PM	CrackMapExec	ksayian	192.168.99.20	SMB authenticated. All domain users enumerated.

Time	Tool	Account Used	Source IP	Result
10:53 PM	CrackMapExec	Administrator	192.168.99.20	PWNED! Full admin access confirmed. All shares accessible.

4. Enumeration Results

4.1 Anonymous Enumeration (enum4linux -a)

Running enum4linux without credentials revealed the following:

- Domain name: HUEYLAB
- Domain SID: S-1-5-21-2401814726-3939285119-1874724425
- Domain Controller: WIN-430KUCVRBB4
- MAC Address: 00-0C-29-47-3B-E3
- Null sessions allowed (server accepted blank username/password connection)
- Users, groups, shares, and password policy all blocked with NT_STATUS_ACCESS_DENIED

4.2 Authenticated Enumeration (enum4linux -a -u ksayan)

Running enum4linux with valid domain credentials revealed significantly more information:

Users Discovered:

Account	Full Name	RID	Notes
Administrator	(null)	0x1f4	Built-in domain admin
Guest	(null)	0x1f5	Built-in guest account
krbtgt	(null)	0x1f6	Kerberos service account
Tennis	(null)	0x3e8	Local admin account
ksayan	Kakarot Sayian	0x44e	Domain user
Vsayan	Vegeta Sayian	0x44f	Domain user

Password Policy Discovered:

- Minimum password length: 7 characters (weak)
- Password complexity: Enabled
- Maximum password age: 41 days 23 hours
- Account Lockout Threshold: NONE — brute force attacks possible without lockout
- Password history length: 24

Network Shares Discovered:

- NETLOGON — Accessible (READ, WRITE)
- SYSVOL — Accessible (READ)
- ADMIN\$ — Access denied for ksayian
- C\$ — Access denied for ksayian

5. CrackMapExec SMB Attack

5.1 User Enumeration

Command used:

```
crackmapexec smb 192.168.99.10 -u ksayian -p Adman123# --users
```

Result: Successfully enumerated all 6 domain users over SMB despite LDAP being blocked. Windows Server 2025 blocked LDAP enumeration but allowed SMB-based enumeration with valid credentials.

5.2 Administrator Access (Pwn3d!)

Command used:

```
crackmapexec smb 192.168.99.10 -u Administrator -p Adman123# --shares
```

Result: CRITICAL — Administrator account used the same password as ksayian (Adman123#). CrackMapExec confirmed full administrative access with the (Pwn3d!) flag.

Shares Accessible as Administrator:

Share	Permissions	Significance
ADMIN\$	READ, WRITE	Remote administration share — full server control
C\$	READ, WRITE	Entire C: drive accessible — all files readable
IPC\$	READ	Inter-process communication
NETLOGON	READ, WRITE	Can modify logon scripts — malware persistence possible
SYSVOL	READ	Group Policy files accessible

6. Security Vulnerabilities Identified

Vulnerability	Severity	Details	Recommendation
Password Reuse	CRITICAL	Administrator and ksayian share the same password (Adman123#). Compromising one account compromised the entire domain.	Enforce unique passwords for all accounts. Use a password manager.
No Account Lockout	HIGH	Account Lockout Threshold is set to None. Attackers can brute force passwords indefinitely without being locked out.	Set lockout threshold to 5 attempts with 30 minute lockout duration.
Weak Minimum Password Length	MEDIUM	Minimum password length is only 7 characters. Modern standards recommend 12-16 minimum.	Increase minimum password length to 14 characters.
Tennis Account in Admins	HIGH	The Tennis local account is a member of the Domain Administrators group unnecessarily.	Follow principle of least privilege. Remove Tennis from Domain Admins.
Null Sessions Allowed	MEDIUM	Server accepts anonymous SMB connections revealing domain information without credentials.	Restrict anonymous access via Group Policy.

7. Blue Team Log Analysis

7.1 Event ID 4624 — Successful Logon

Filtered Security logs for Event ID 4624 revealed the attack pattern clearly. The following forensic evidence was captured from a single event log entry:

Field	Value	Significance
Account Name	ksayian	Compromised account used in attack
Workstation Name	kali	Attack originated from Linux machine named kali
Source Network Address	192.168.99.20	Kali Linux IP address
Logon Type	3	Network logon — remotely initiated
Authentication Package	NTLM V2	CrackMapExec used NTLM authentication
Logon Process	NtLmSsp	Confirms SMB-based authentication

7.2 Attack Pattern Detection

The attack was clearly visible in the logs through the following indicators:

- Multiple successful logons from 192.168.99.20 within seconds of each other
- Logon Type 3 (network) from a machine named 'kali' — highly suspicious
- NTLM authentication from a Linux machine — unusual in a Windows domain
- Rapid burst of 4624 events at identical timestamps — automated tool signature

In a real SOC environment these indicators would trigger:

- SIEM alert for rapid authentication attempts from single source
- Alert for authentication from non-standard workstation name
- Incident ticket for investigation and response
- Potential isolation of source IP 192.168.99.20

8. Kerberoasting Attempt

Kerberoasting was attempted using `impacket-GetUserSPNs` but was blocked by Windows Server 2025's enhanced LDAP security requirements. The server requires LDAP channel binding and signing which prevented the standard Kerberoasting workflow.

Steps taken:

- Registered SPN on `ksayian` account: `setspn -A HTTP/webserver.hueylab.local ksayian`
- Obtained Kerberos TGT with `kinit ksayian@HUEYLAB.LOCAL`
- Set `KRB5CCNAME` environment variable to point to ticket cache
- Multiple `impacket-GetUserSPNs` attempts all returned `ECONNRESET`
- Root cause: Windows Server 2025 enforces LDAP channel binding by default

Note: This is actually a realistic scenario. Modern hardened environments block many traditional attack tools. Real penetration testers must adapt their methodology based on server security configurations. `CrackMapExec` succeeded where `impacket` failed by using SMB instead of LDAP.

9. Key Lessons Learned

- Password reuse is the most dangerous vulnerability in any environment — one compromised account can lead to full domain takeover
- Windows Server 2025 has significantly stricter LDAP security than previous versions — attack tools must be adapted
- Every attack leaves forensic evidence in Windows Security logs — nothing is invisible
- A SOC analyst can identify attacker tools, source IP, account used, and exact timestamps from a single Event ID 4624 entry
- The absence of account lockout policy is a critical gap that enables brute force and password spraying attacks

- CrackMapExec is more reliable than impacket against hardened Windows Server 2025 environments

10. Next Steps for Phase 4

- Install and configure Splunk on Windows Server for SIEM capability
- Create Splunk alerts for rapid authentication attempts (>3 logons in 5 seconds from same IP)
- Fix the identified vulnerabilities: password policy, account lockout, password reuse
- Install BloodHound on Kali for Active Directory attack path visualization
- Practice Pass-the-Hash attacks using captured NTLM hashes
- Set up a Windows 10 workstation VM as a third lab machine
- Practice lateral movement techniques between lab machines
- Document remediation steps for each vulnerability identified in Phase 3